

Threats, vulnerabilities, and mitigations (22%)

2.1 Threat Actors & Motivations

Threat Actor – Any entity responsible for a security event against another entity.

Attribute	Description
Internal/External	Internal = inside the org; External = outside
Resources/Funding	Level of financial and technical backing
Sophistication	Skill level and capability of the actor

Threat Actor Types:

- **Nation-state** – Government-sponsored; highly sophisticated, well-funded; motivations: espionage, disruption, warfare
- **Hactivist** – Ideologically motivated; targets organizations for political/social reasons
- **Organized crime** – Financially motivated; ransomware, fraud, data theft
- **Insider threat** – Current/former employee; has existing access; hardest to detect
- **Shadow IT** – Employees using unapproved systems/apps; unintentional threat
- **Script kiddie** – Low skill; uses existing tools/exploits without deep knowledge

Motivations: Data exfiltration, financial gain, espionage, disruption, philosophical/political beliefs, revenge

2.2 Threat Vectors & Attack Surfaces

Threat Vector – The method a threat actor uses to gain access.

Message-based: Email, SMS (smishing), IM — most common delivery method for phishing/malware

Other vectors:

- **Image-based** – Malicious code embedded in image files
- **File-based** – Malicious code hidden in documents (PDFs, Word docs)
- **Voice call** – Vishing (voice phishing)
- **Removable device** – USB drives; can auto-execute malware
- **Vulnerable software** – Client-based (requires installed agent) vs. Agentless (no agent needed)
- **Unsupported systems** – No patches = permanent vulnerabilities
- **Unsecured networks** – Wireless, wired, Bluetooth; open ports, weak firewall rules
- **Open service ports** – Close unused ports; apply strict firewall rules to necessary ones
- **Default credentials** – Unchanged default usernames/passwords (e.g. admin/admin)
- **Supply chain** – MSPs, vendors, suppliers; audit all third parties

2.2 Human Vectors / Social Engineering

- **Phishing** – Deceptive email to steal credentials or deliver malware
 - **Vishing** – Voice call phishing
 - **Smishing** – SMS phishing
- **Spear phishing** – Targeted phishing aimed at a specific individual or org
- **Business Email Compromise (BEC)** – Attacker impersonates a trusted internal email address
- **Brand impersonation** – Fake emails/sites mimicking a known brand
- **Typosquatting** – Registering misspelled domain names to catch mistyped URLs
- **Pretexting** – Attacker creates a fabricated scenario/story to manipulate the victim

- **Impersonation** – Pretending to be someone else; mitigate by verifying identity before disclosing info
- **Watering hole** – Attacker compromises a site the target frequently visits; mitigation: defense in depth
- **Misinformation/Disinformation** – Spreading false info; misinformation = unintentional, disinformation = intentional

2.3 Vulnerabilities

Application Vulnerabilities

- **Memory injection** – Injecting malicious code into a running process (e.g. via DLL)
- **Buffer overflow** – Writing beyond a variable's memory boundary; can lead to privilege escalation
- **Race condition** – Two processes finish simultaneously; variables may not update in time
 - **TOC (Time-of-Check)** – When the check happens
 - **TOU (Time-of-Use)** – When the resource is actually used; gap between TOC and TOU is the vulnerability
- **Malicious update** – Patching from an unverified source; always verify source + have backups + test first
- **SQLi (SQL Injection)** – Attacker inserts SQL commands via unprotected inputs to access/manipulate databases
- **XSS (Cross-Site Scripting)** – Injecting malicious scripts into web pages viewed by other users
 - **Reflected** – Script returned immediately via URL/input; affects the requesting user
 - **Stored/Persistent** – Script saved on the server; affects all users who load the page
 - **Mitigation** – Validate/sanitize inputs; disable JavaScript where possible

OS & Hardware Vulnerabilities

- **OS vulnerabilities** – Millions of lines of code = many potential flaws; patch immediately when updates release
- **Firmware** – Hardware's embedded OS (routers, IoT); vulnerable and often unpatched; can affect entire network
- **End-of-life (EOL)** – Vendor stops patching; replace before EOL date
- **Legacy systems** – Old unsupported systems; document thoroughly before changes

Virtualization Vulnerabilities

- **VM escape** – Attacker breaks out of a VM to access the host or other VMs
- **Resource reuse** – Shared memory/storage between VMs; data remnants from previous use may be accessible

Other Vulnerabilities

- **Cloud-specific** – Misconfigured storage buckets, over-permissioned accounts, shared responsibility gaps
- **Supply chain** – Compromised hardware/software from vendors before it reaches your org
- **Cryptographic** – Weak algorithms, short key lengths, improper implementation
- **Misconfiguration** – Open ports, default credentials, unnecessary services running
- **Mobile – Side loading** – Installing apps outside official app store; bypasses security review
- **Mobile – Jailbreaking** – Removing OS restrictions; circumvents built-in security controls
- **Zero-day** – Unknown vulnerability with no available patch; mitigate with defense in depth + rapid patching

2.4 Malicious Activity

Malware Types

Malware	Key Detail
Ransomware	Encrypts files; demands payment for decryption key
Trojan	Appears legitimate (PDF, doc); contains hidden malware
Worm	Self-replicates across networks without user interaction
Spyware	Monitors user activity; exfiltrates data
Bloatware	Pre-installed unwanted software; potential attack surface
Virus	Attaches to files; spreads when file is opened/shared
Keylogger	Records keystrokes; captures passwords and sensitive data
Logic bomb	Triggers at a specific time or event; destroys/corrupts data
Rootkit	Embeds in OS/system files; hides itself; very hard to remove

Physical Attacks

- **Brute force** – Trying every possible password combination
- **RFID cloning** – Copying access card data to a blank card; used to bypass physical access controls
- **Environmental** – Attacking physical infrastructure (power, HVAC, flooding)

Network Attacks

- **DoS (Denial of Service)** – Floods a server with traffic (e.g. SYN flood) to make it unavailable
- **DDoS (Distributed DoS)** – DoS from many systems simultaneously
 - **Amplified** – Attacker spoofs victim's IP; response traffic is much larger than request (e.g. DNS amplification)
 - **Reflected** – Traffic is bounced off legitimate servers back to the victim
- **On-path attack (MITM)** – Attacker intercepts traffic between two parties; can read or modify data
- **DNS attack** – Poisoning DNS cache to redirect users to malicious sites
- **Credential replay** – Capturing and reusing valid session tokens/cookies to authenticate as the victim

Application Attacks

- **Injection** – Inserting malicious input (SQL, code) into an application
- **Buffer overflow** – Overwriting memory to execute arbitrary code or escalate privileges
- **Replay** – Capturing session ID/cookies and reusing them to hijack a session
- **Privilege escalation** – Gaining higher access than intended (user → admin/root)
- **Forgery (CSRF)** – Tricks authenticated user into submitting a malicious request
- **Directory traversal** – Using `../` to navigate outside the web root and access restricted files

Cryptographic Attacks

- **Downgrade** – Forces connection to use weaker/older encryption (e.g. HTTPS → HTTP via on-path attack)
- **Collision** – Two different inputs produce the same hash; breaks integrity (MD5 is vulnerable)
- **Birthday attack** – Exploits collision probability; finds two inputs with same hash faster than brute force

Password Attacks

- **Spraying** – Tries a few common passwords across many accounts; avoids logout
- **Brute force** – Tries every possible combination for one account

Indicators of Compromise (IoCs)

Account lockout, concurrent session usage, blocked content, impossible travel, resource consumption, resource inaccessibility, out-of-cycle logging, missing logs

2.5 Mitigation Techniques

Technique	Key Detail
Segmentation	Separate networks by function (Finance ≠ HR); limits lateral movement
Access Control	ACLs + permissions; control who accesses what
Allow list	Only approved applications can run; very restrictive
Isolation	Quarantine compromised systems until patched
Patching	Fix known vulnerabilities; prioritize critical patches
Encryption	Protect data at rest and in transit
Monitoring/SIEM	Log everything; correlate events for threat detection
Least privilege	Users get only the access needed to do their job
Configuration enforcement	Enforce secure baselines; prevent drift
Decommissioning	Properly retire old hardware/software so it's no longer a threat vector

Hardening Techniques:

- Encryption
- Endpoint protection (AV/EDR)
- Host-based firewall
- Host-based IPS (HIPS)
- Disable unused ports/protocols
- Change default passwords
- Remove unnecessary software